École Nationale des Sciences Appliquées de Beni Mellal
Université Sultan Moulay Slimane

Filière : Intelligence Artificielle et Cybersécurité

Module : Administration sécurisée et forensics

Projet : Détection et analyse d'une compromission sur un serveur Linux

---

1. Contexte général

Une petite organisation dispose d'un unique serveur Linux accessible sur son réseau interne. Récemment, plusieurs signaux inquiétants ont été observés comme des connexions SSH à des horaires inhabituels, la création d'un nouvel utilisateur sans justification claire et une activité réseau suspecte laissant supposer une possible compromission. En tant qu'administrateur sécurité, votre mission consiste d'abord à :

- Sécuriser le serveur
- Mettre en place une journalisation exploitable
- Détecter une attaque simulée
- Analyser la compromission
- Produire un mini rapport d'investigation

2. Environnement requis

2 machines virtuelles :

- VM1 : Serveur Linux (Ubuntu)
- VM2 : Machine attaquante (Kali Linux)

3. Travail demandé

3.1 Modèle de menace

- ✓ Identifier les actifs critiques du serveur
- ✓ Identifier les surfaces d'attaque (SSH, comptes, services actifs)
- ✓ Définir un scénario réaliste : Bruteforce SSH + élévation de privilège

3.2 Hardening de base du serveur

- ✓ Désactiver connexion root SSH
- ✓ Mettre en place authentification forte (clé ou politique mot de passe)
- ✓ Configurer pare-feu

- ✓ Supprimer comptes inutiles
- ✓ Activer mises à jour automatiques
- ✓ Appliquer le principe du moindre privilège (sudo contrôlé)

3.3 Mise en place de la journalisation

- ✓ Activer et vérifier journaux SSH
- ✓ Configurer auditd ou améliorer la journalisation Syslog
- ✓ Synchroniser l'heure (NTP)
- ✓ Identifier les fichiers logs critiques

Vous devez démontrer que vous savez :

- ✓ Où se trouvent les logs
- ✓ Quels événements sont importants
- ✓ Comment lire et filtrer les logs

3.4 Simulation d'attaque contrôlée

Depuis la VM attaquante :

- ✓ Lancer un bruteforce SSH contrôlé (hydra par exemple)
- ✓ Créer un utilisateur suspect
- ✓ Tenter une élévation de privilège
- ✓ Lancer une connexion sortante inhabituelle

3.5 Détection et analyse

- ✓ Identifier les traces dans les logs
- ✓ Déterminer :
  - Heure de l'attaque
  - Compte compromis
  - Actions réalisées
- ✓ Identifier des IOC(Indicators of Compromise) :
  - IP source
  - Compte suspect
  - Commandes exécutées

Vous devez reconstituer une chronologie simple.

3.6 Réponse à incident

- ✓ Isoler temporairement le serveur (règle firewall)
- ✓ Supprimer compte malveillant
- ✓ Changer mots de passe
- ✓ Vérifier absence de persistance simple (cron, ssh keys)

3.7 Mini rapport forensique (5 pages max)

Le rapport doit contenir :

- ✓ Description de l'incident
- ✓ Méthodologie
- ✓ Preuves extraites (logs)
- ✓ Chronologie
- ✓ Impact
- ✓ Recommandations